

# The Incident Response Lifecycle (NIST 800-61)

## The Six Phases

NIST SP 800-61 defines the process:

1. Preparation
2. Detection & Analysis
3. Containment, Eradication & Recovery
4. Post-Incident Activity

Popular 6-step framing adds the middle:

Prepare → Detect → Contain → Eradicate → Recover → Lessons Learned

## Phase 1 – Preparation (Before Anything Happens)

**IR Plan** – who does what when the pager goes off

**Playbooks** – step-by-step for the common types (ransomware, phish, insider)

**Access when it counts** – emergency admin access that actually works when AD is compromised

**Tools** pre-deployed (EDR, SIEM, containment switches)

**Contacts** – vendors, legal, PR, cyber insurance, law enforcement

**Backups you can actually restore** (tested!)

The best IR happens because of the preparation 12 months earlier. If you only prepare when the incident starts, you've lost.

## Phase 2 – Detection & Analysis

**Triage** (module 12) → confirmation

The five W's again: what, who, when, where, why

**Scope** – how far has it spread? (that's the biggest question at the start)

Establish **IDs/labels**: incident #, case naming, comms channels

## Phase 3 – Containment

Goal: stop the bleeding WITHOUT destroying evidence.

**Short-term**: isolate hosts (kick from network), kill the pipes (block C2)

**Preserve**: snapshot, memory capture *before* you pull the plug (M14)

**Long-term**: temporary fix to run business safely while you continue

Decision: to contain means changes to the environment – **document every change** and why

## Phase 4 – Eradication

Remove the attacker's footholds:

Malware, backdoors, persistence

Reset ALL affected credentials (they may have more)

Patch the *cause*, not just the symptom

## Phase 5 – Recovery

Restore from clean backups

**Careful**: restore to a *clean* state and validate

Reinstate business functions under monitoring

The attacker may re-enter – watch for re-compromise (a well-known failure)

## Phase 6 – Lessons Learned

The phase most teams skip and regret:

What worked / what didn't

Root cause to fix – permanently

Update the playbook, close the gap

**Key mindset:** recovery isn't "everything works again" – it's "we understand what happened, why, and how we'll prove it won't happen the same way."

---

[← Module start](#)

[Playbooks & Confirmed Incident...](#)